vm-grc-01 Remote Access Policy

Nov 10, 2026 · @Tyrell

1. Purpose and scope

All administrative access to vm-grc-01 must go through Azure Bastion or Azure management-plane tools, using MFA to the portal and SSH keys to the VM; no other remote access path is permitted.

This policy implements NIST SP 800-53 Rev. 5 AC-17 (Remote Access) for the vm-grc-01 GRC lab. It covers every person and service that connects to the VM or changes its configuration: the Azure portal, Azure Bastion, VM Run command, Cloud Shell, and Azure Policy remediation. It applies to resource group rg-grc-lab in the Azure for Students subscription.

2. Policy statements

2.1 Approved access methods

Method	Allowed use	Conditions
Azure Bastion (SSH over HTTPS 443)	Interactive administration	Deployed only for the session and deleted afterward
VM Run command	One-off configuration changes and checks	Commands and output recorded in the evidence log
Azure portal and Cloud Shell	Management-plane changes, policy scans	Signed in with the St. John's account and MFA
Azure Policy remediation tasks	Automated configuration fixes	Initiated by the system owner; results reviewed

Any other path is prohibited, including a public IP on the VM, an NSG rule allowing inbound SSH or RDP, VPN, or third-party remote tools.

2.2 Authentication

- Portal access requires MFA, enforced by the St. John's Entra ID tenant.

- VM login uses SSH public keys only. Password authentication and root login are disabled in sshd.
- The SSH private key is stored only on the administrator's device. It is never emailed, uploaded, or committed to a repository.
- A lost or exposed key is reported and replaced the same day using the VM access reset feature.

2.3 Network controls

- The VM has no public IP and sits in a private subnet.
- nsg-vm denies all inbound traffic from the internet. Adding an allow rule requires a documented change with a justification and an end date.
- Outbound internet access exists only through a NAT gateway during patching sessions.

2.4 Session management

- Bastion and the NAT gateway are deleted at the end of each session, and the VM is stopped.
- The VM auto-shuts down daily at 7:00 PM Eastern as a backstop.
- Bastion sessions close automatically after a period of inactivity.

2.5 Logging and review

- Azure Activity Log records every management-plane action, including Bastion deploys, Run command use, and policy remediation.
- The system owner reviews the Activity Log monthly for unexpected access or changes.
- Central log collection (Log Analytics) is planned under POAM-08.

3. Roles, exceptions, and review

- **System owner and administrator (Tyrell Freeman):** the only authorized remote user. Approves and records any change to the access paths in this policy.
- **St. John's University:** operates Entra ID and enforces MFA (inherited).
- **Microsoft Azure:** operates the Bastion service and the management plane (inherited).

Exceptions must be written down before use, with the reason, the compensating controls, and an end date no more than 7 days out. Each exception is added to the POA&M and removed when it expires.

Enforcement: any unapproved access path found (for example, a public IP or an inbound allow rule) is removed immediately and logged as a finding.

Review: this policy is reviewed every 6 months, and whenever the architecture changes. Next review: 2027-05-10.

4. Control mapping and evidence

Control	Policy section	Evidence
AC-17 Remote Access	2.1, 2.3	E02, E04, E05
AC-17(1) Monitoring and Control	2.5	Activity Log (POAM-08 for central logging)
AC-17(2) Encryption Using Cryptographic Mechanisms	2.1 (HTTPS to Bastion, SSH to VM)	E05
AC-17(3) Managed Access Control Points	2.1	E05
AC-17(4) Privileged Commands and Access	2.1 (Run command rules)	F07
IA-2(1) MFA for Privileged Accounts	2.2	E01
IA-5 Authenticator Management	2.2	E06, F07
SC-7 Boundary Protection	2.3	E03, E04, B06
AC-12 Session Termination	2.4	E09, B14
CM-3 Configuration Change Control	2.3, 3	Evidence log